

Incident Handling (IH) is a set of procedures used by organizations to manage and respond to cybersecurity threats [cite: 1]. It is essential for protecting data confidentiality, integrity, and availability [cite: 1].

1. Key Definitions

- **Event:** Any action on a system or network (e.g., a user sending an email or a firewall allowing a connection) [cite: 1].
- **Incident:** An event with negative consequences, such as a system crash, data theft, or unauthorized access [cite: 1].
- **Incident Handling:** A defined process to identify, contain, eradicate, and recover from security incidents to restore normal operations [cite: 1].

2. Why Incident Handling Matters

- It helps organizations respond quickly and systematically to security breaches [cite: 1].
- A dedicated "Incident Response Team" minimizes the loss of information and service disruptions [cite: 1].
- An **Incident Manager** leads the team, tracking investigation progress and coordinating with other business units [cite: 1].

3. Common Types of Real-World Incidents

- **Leaked Credentials:** Using compromised passwords (e.g., Colonial Pipeline ransomware attack) [cite: 1].
- **Default/Weak Credentials:** Using factory settings (e.g., admin/admin), which led to the Mirai botnet attack [cite: 1].
- **Outdated Software:** Failing to apply patches for known vulnerabilities (e.g., Equifax and WannaCry breaches) [cite: 1].
- **Insider Threats:** Abuse of access by former or current employees (e.g., Cash App breach) [cite: 1].
- **Phishing/Social Engineering:** Tricking users into revealing credentials or enabling remote access (e.g., 2020 Twitter hack) [cite: 1].
- **Supply-Chain Attacks:** Compromising software updates distributed to customers (e.g., SolarWinds attack) [cite: 1].

4. Documentation and Reporting

- Professionals use frameworks like the **Cyber Kill Chain** and **MITRE ATT&CK** to document

incidents step-by-step [cite: 1].

- Incident reports help organizations learn from past events and identify emerging trends to improve their defenses [cite: 1].

Key Takeaways

- Incident handling is a necessary defensive capability for any organization [cite: 1].
- Security depends on strong passwords, patched software, and monitoring insider access [cite: 1].
- You can explore professional incident reports at thedfirreport.com to see real-world examples [cite: 1].

Incident Handling Process: Comprehensive Guide

Section 1: Incident Handling Definition & Scope

Incident Handling (IH) is a systematic approach to managing and responding to cybersecurity incidents [cite: 1].

Key Concepts

- **Event:** Any action on a system or network (e.g., a user click or a firewall connection request) [cite: 1].
- **Incident:** An event with negative consequences, such as data theft, system crashes, or unauthorized access [cite: 1].
- **Goal:** To identify, contain, eradicate, and recover from security incidents to restore normal business operations efficiently [cite: 1].

Real-World Incident Types

- **Leaked/Weak Credentials:** Often leads to unauthorized access (e.g., Colonial Pipeline attack) [cite: 1].
- **Outdated Software:** Exploiting unpatched vulnerabilities (e.g., WannaCry, Equifax) [cite: 1].
- **Phishing/Social Engineering:** Tricking users into revealing credentials or running malicious payloads [cite: 1].
- **Supply-Chain Attacks:** Compromising software updates at the source (e.g., SolarWinds) [cite: 1].
- **Insider Threats:** Abuse of legitimate access by employees [cite: 1].

Section 2: Cyber Kill Chain & MITRE ATT&CK

The Cyber Kill Chain (Attack Lifecycle)

This framework describes the seven stages an attacker goes through [cite: 2]:

1. **Reconnaissance**: Gathering information about the target [cite: 2].
2. **Weaponize**: Creating and embedding malware into a payload [cite: 2].
3. **Delivery**: Sending the payload to the victim (e.g., via phishing) [cite: 2].
4. **Exploitation**: Triggering the exploit to gain access [cite: 2].
5. **Installation**: Installing backdoors or rootkits on the system [cite: 2].
6. **Command and Control (C2)**: Establishing a remote communication channel [cite: 2].
7. **Action**: Achieving the final objective, such as data theft or encryption (ransomware) [cite: 2].

MITRE ATT&CK Framework

A detailed knowledge base of adversary behavior used by professionals to detect and respond to threats [cite: 2].

- **Tactic**: The attacker's high-level goal (e.g., Initial Access, Persistence) [cite: 2].
- **Technique**: The specific method used to achieve a tactic (e.g., T1003.001 - LSASS Memory Dumping) [cite: 2].

Pyramid of Pain

Defenders can cause more "pain" to attackers by moving from detecting simple indicators (Hash/IP) to detecting advanced **TTPs (Tactics, Techniques, and Procedures)** [cite: 2].

Tips for Success

- **Integration**: Use platforms like **TheHive** to centralize alerts and map them to MITRE ATT&CK techniques [cite: 2].
- **Focus**: Always try to stop attackers in the earliest possible stage of the Cyber Kill Chain [cite: 2].

Incident Handling Process: Main Activities & Stages

1. The Incident Handling Process (NIST Framework)

The process is cyclic, meaning as new evidence is found, steps may need to be repeated [cite: 3]. It consists of four distinct stages:

- **Preparation**: Preparing the organization to handle potential security incidents [cite: 3].

- **Detection and Analysis:** Identifying malicious events and analyzing their scope [cite: 3].
- **Containment, Eradication, and Recovery:** Limiting the damage, removing the threat, and restoring systems [cite: 3].
- **Post-Incident Activity:** Reporting, documenting lessons learned, and implementing changes to prevent future incidents [cite: 3].

2. Two Main Activities

Incident handling primarily focuses on these two core activities:

- **Investigating:**
 - Identifying 'patient zero' (the first victim) [cite: 3].
 - Creating a timeline of the incident [cite: 3].
 - Determining which tools/malware the adversary used [cite: 3].
 - Documenting all compromised systems and attacker actions [cite: 3].
- **Recovering:**
 - Creating and implementing a recovery plan [cite: 3].
 - Resuming normal business operations [cite: 3].

3. Important Rules for Handlers

- **Do not skip steps:** Complete one stage before moving to the next [cite: 3].
- **Avoid incomplete containment:** For example, do not contain only some infected machines while leaving others active, as this alerts the attacker to your investigation [cite: 3].
- **Continuous Monitoring:** Even when responding to an incident, resources should always be operating in the "Preparation" and "Detection" stages [cite: 3].

Summary Table: Incident Handling vs. Cyber Kill Chain

Feature	Cyber Kill Chain	Incident Handling Process
Purpose	Describes attacker lifecycle [cite: 2]	Describes defender response lifecycle [cite: 3]
Nature	Attacker perspective [cite: 2]	Defender/Organization perspective [cite: 3]
Stages	7 stages (Recon to Action) [cite: 2]	4 stages (Prep to Post-incident) [cite: 3]

Note: Incident handling contains two main activities—Investigating and Recovering, NOT Investigating and Reporting [cite: 3].

Incident Handling: Preparation Stage

Preparation is the foundation of a successful incident response. It ensures that the organization is ready to defend, detect, and respond to threats efficiently [cite: 4].

1. Key Objectives

- **Capability Building:** Establishing an in-house or outsourced Incident Response (IR) team [cite: 4].
- **Prevention:** Implementing security measures like MFA, server hardening, and Privileged Access Management (PAM) [cite: 4].

2. Essential Prerequisites

- **Skilled Team:** Trained personnel who understand incident handling procedures [cite: 4].
- **Clear Documentation:**
 - **Policies & Plans:** Updated incident response plans and communication procedures [cite: 4].
 - **Network Maps & Asset Databases:** Knowing exactly what is on your network [cite: 4].
 - **Forensic Cheat Sheets:** Quick-reference guides for investigators [cite: 4].
- **Legal & Compliance:** Knowing communication requirements for law enforcement and regulatory bodies (e.g., GDPR) [cite: 4].

3. The "Jump Bag" Concept

A **Jump Bag** is a pre-packed kit containing all necessary software and hardware tools that incident handlers can grab and take to an incident immediately [cite: 4].

- **Includes:** Forensic imaging tools, network cables, write blockers, hard drives, power cables, and basic hardware repair tools [cite: 4].

4. Operational Best Practices

- **Independent Infrastructure:** Always maintain a documentation and communication system that is **completely independent** of the organization's main network [cite: 4]. Assume the attacker can read your internal emails [cite: 4].
- **Baselines:** Use a "Golden Image" (a known clean state of a system) to create baselines. This helps detect deviations or unauthorized changes easily [cite: 4].
- **Effective Logging:** During an investigation, keep detailed notes answering the "5 Ws":
 - **Who** performed the action?
 - **What** was the activity?
 - **When** did it happen? (Timestamps)

- **Where** did it happen?
 - **Why/How** was it done? [cite: 4].
-

Summary Checklist

- ☐ Is the Incident Response team trained? [cite: 4]
- ☐ Is the Jump Bag packed and ready? [cite: 4]
- ☐ Are network diagrams and asset lists up to date? [cite: 4]
- ☐ Is the reporting system secured and off-network? [cite: 4]

Preparation Stage: Protective Measures

Protecting the organization is critical to reducing the attack surface. While incident handlers focus on responding, knowing these measures helps them during forensic investigations.

1. Email & Identity Security

- **DMARC**: Blocks spoofed emails that pretend to come from your domain.
- **Passphrases**: Use long, complex phrases (e.g., "i LIK3 my coffeE warm") instead of standard complex passwords (e.g., "Summer2021!"), which are easily guessed.
- **MFA**: Essential for all administrative access.

2. Endpoint & Network Security

- **Endpoint Hardening**:
 - Disable LLMNR/NetBIOS.
 - Use LAPS to manage local admin passwords.
 - Block execution from user-writable folders (Downloads, Desktop, AppData).
- **Network Segmentation**: Isolate critical systems to stop lateral movement.
- **EDR/AMSI**: Deploy EDR tools that integrate with AMSI for deep visibility into scripts.

3. Continuous Improvement

- **Vulnerability Management**: Automate scanning and manually patch high/critical vulnerabilities.
- **Purple Team Exercises**: Joint exercises between offensive (Red) and defensive (Blue) teams to test monitoring, detection, and incident response playbooks.
- **User Training**: Conduct regular phishing simulations and security awareness sessions.

4. Why AD Assessments Matter

- Many attackers use Active Directory (AD) escalation paths. Regular AD security reviews help identify "low-hanging fruit" (easy-to-exploit misconfigurations) before an attacker does.

Incident Handling: Detection & Analysis Stage

Detection and Analysis is the stage where security teams identify malicious events using tools, logs, and human expertise.

1. Sources of Detection

Threats can be identified through various channels:

- **Employees:** Reporting abnormal behavior.
- **Security Tools:** Alerts from EDR, IDS, SIEM, and Firewalls.
- **Threat Hunting:** Proactive searching for hidden threats.
- **Third-Party Notifications:** External partners informing the organization of a compromise.

2. Categorizing Detection Layers

To improve visibility, categorize detection into four levels:

- **Network Perimeter:** Firewalls, DMZ, and internet-facing IDS/IPS.
- **Internal Network:** Local firewalls and internal IDS.
- **Endpoint:** Antivirus, EDR, and Host-based monitoring.
- **Application:** Service logs and application-level telemetry.

3. Initial Investigation Workflow

Once an incident is detected, answer these key questions before escalating:

- **Who/When:** Who reported the incident and at what time?
- **What:** What is the nature of the event (e.g., Phishing, Malware, Data Breach)?
- **Impact:** Which systems are affected? Are they business-critical?
- **State:** Is the incident ongoing or has it been contained?

4. Incident Timeline

Building a timeline is essential to organize evidence chronologically.

- **Goal:** To understand the attacker's behavior and the progression of the attack.
- **Required Columns:** Date/Time, Hostname, Event Description, and Data Source.
- **Example:**
| Date/Time | Hostname | Event Description | Data Source |

5. Severity & Confidentiality

- **Assessment:** Evaluate impact using questions like "How many systems are affected?" and "Does it have worm-like capabilities?"
 - **Confidentiality:** Treat incident info on a "need-to-know" basis. Assume internal communication channels (like email) may be compromised by the adversary.
-

Summary Checklist

- ☐ Determine the detection source and confirm incident type.
- ☐ Identify all impacted systems and their owners.
- ☐ Build a preliminary incident timeline.
- ☐ Assess severity to determine escalation needs.
- ☐ Secure communication channels (avoid using company email for incident updates).

Detection & Analysis: Investigation Cycle

The investigation is a cyclic process to uncover "how" an attack happened and "what" was impacted.

1. The 3-Step Investigative Cycle

- **IOC Creation:** Defining signs of compromise using formats like YARA or STIX.
- **Leads Identification:** Using IOCs to find other compromised systems.
- **Data Analysis:** Forensic analysis of collected data (Disk/Memory forensics, Malware analysis).

2. Best Practices

- **Know Your Tools:** Use connection protocols (like WinRM) that do not cache credentials on remote systems.
- **Chain of Custody:** Keep track of forensic data to ensure it is court-admissible.
- **Avoid Narrow Focus:** Do not focus only on one specific tool (like Mimikatz); look for broader attacker activity to avoid missing the full scope.

3. AI in Threat Detection

- AI automates log review, clusters related alerts, and maps incidents to the **MITRE ATT&CK** framework, significantly reducing incident response time.

4. Operational Rule

- **No Isolation:** Never ignore a security alert just because it belongs to another department. Always escalate incidents to ensure organizational security.

Incident Handling: Containment, Eradication & Recovery

After the investigation, the goal is to stop the damage, remove the threat, and restore operations.

1. Containment (Two Types)

- **Short-term:** Quick, low-footprint actions to stop the spread (e.g., disconnecting a machine from the network, isolation VLANs). Best for evidence preservation.
- **Long-term:** Permanent changes (e.g., password resets, firewall rules, patching).

2. Eradication

The phase where we eliminate the root cause.

- **Actions:** Malware removal, system rebuilding, restoring from clean backups, and additional system hardening.

3. Recovery

Bringing systems back to production.

- **Monitoring:** Essential! All restored systems must be under heavy logging to detect any re-entry by the adversary.
- **Phased approach:** Large incidents are managed in phases, starting with "quick wins" and moving to long-term security.

Summary Checklist

- ☐ Is containment coordinated across all systems simultaneously?
- ☐ Has the root cause been eliminated in the Eradication phase?
- ☐ Are restored systems under strict monitoring for suspicious activity?
- ☐ **Crucial Rule:** If IOCs are still appearing, DO NOT continue recovery. Escalate back to the

Investigation phase.

Incident Handling: Post-Incident Activity

After the incident is fully resolved, the focus shifts to documentation, analysis, and process improvement.

1. Key Objectives

- **Lessons Learned:** Understanding the "what," "why," and "how" of the incident.
- **Process Improvement:** Updating playbooks, policies, and procedures based on team performance.
- **Knowledge Sharing:** Training team members (especially juniors) using real-world incident case studies.

2. The Final Report

The report is a vital document for management, legal teams, and future incident reference. It must answer:

- **Timeline:** What happened and when?
- **Performance:** How effective were our response plans and tools?
- **Remediation:** What was done to contain and eradicate the threat?
- **Preventive Measures:** What changes are needed to prevent a recurrence?

3. Measurable Outcomes

- Use report data to track incident frequency, team response time, and resource usage.
- Evaluate if tools, training, and team structure need adjustment for better future readiness.

Summary Checklist

- ☐ Hold a "lessons learned" meeting with all stakeholders.
- ☐ Finalize the incident report with full documentation.
- ☐ Update playbooks and policies based on identified gaps.
- ☐ Use the incident as a training exercise for the team.

Case Study: Insight Nexus Breach Analysis

1. Threat Actors

- **Crimson Fox:** State-backed, high-skill, focused on long-term persistence and data exfiltration.
- **Silent Jackal:** Low-skill, opportunistic, focused on defacement ("checkme.txt").

2. Attack Lifecycle

- **Initial Access:**
 - ManageEngine ADManager Plus (Default credentials).
 - PHP Application (Unpatched file upload vulnerability).
- **Persistence:** GPO-deployed MSI package (java-update.msi).
- **Exfiltration:** Sensitive data compressed into `diagnostics_data.zip` and exfiltrated via HTTPS.

3. Organizational Oversights

- **Lack of MFA:** Default credentials on management consoles.
- **Alert Fatigue:** Ignoring "file creation" alerts led to missing the initial foothold.
- **Poor Correlation:** Failing to link disparate events (e.g., foreign login + suspicious file creation).

4. Key Takeaways for Defenders

- **Correlate, Don't Isolate:** Always check if multiple alerts in a time window are part of the same campaign.
- **Monitor Exfiltration:** Filenames that look like "diagnostics" or "logs" are often used to hide stolen data.
- **Persistence Scanning:** Simply deleting a web shell or a file does not remove a GPO-based persistent task.